



Secure Enterprise AI for Healthcare

HIPAA-Aligned RAG Demo

Trusted healthcare knowledge with minimum-necessary access, auditability, encryption, and human oversight.



Synthetic data only – no real PHI



Data Protection

Encryption at rest
and in transit



Minimum-Necessary Access

Role-based access
& row-level controls



Auditability

Comprehensive logs
and traceability



Human Oversight

AI-assisted insights
with clinician review



LOCAL MODEL CONTROLLED BOUNDARY

Model stays inside your
approved environment



Audit Log

Time	User	Action	Details
May 20, 2025 10:15	jdoe	Query	Sepsis care guidelines
May 20, 2025 10:16	jdoe	View Source	Clinical Guidelines
May 20, 2025 10:17	jdoe	Response Viewed	Answer ID: 773a...
May 20, 2025 10:21	jdoe	Export	Summary (no PHI)



Oracle Database 26ai + Local LLM | Private. Secure. Controlled.

The opportunity: trusted answers without widening the PHI boundary

Healthcare teams lose time moving between patient facts, policy, payer rules and operational systems.

Information friction

Staff hunt through multiple systems and documents before they can act with confidence.

Privacy constraint

The answer must respect identity, patient scope, purpose of use and minimum necessary access.

Safety constraint

AI can synthesize evidence, but consequential clinical or operational actions need bounded authority.

Audit need

Leaders need to know what data was used, what the model did and who approved the action.

CareGuard AI compresses the search-and-synthesis work while keeping authorization, evidence and human accountability visible.

RAG + VECTOR

MINIMUM NECESSARY

HUMAN APPROVAL

One synthetic discharge case becomes the whole demo

The scenario is familiar, operationally useful, and safe to reproduce without real PHI.

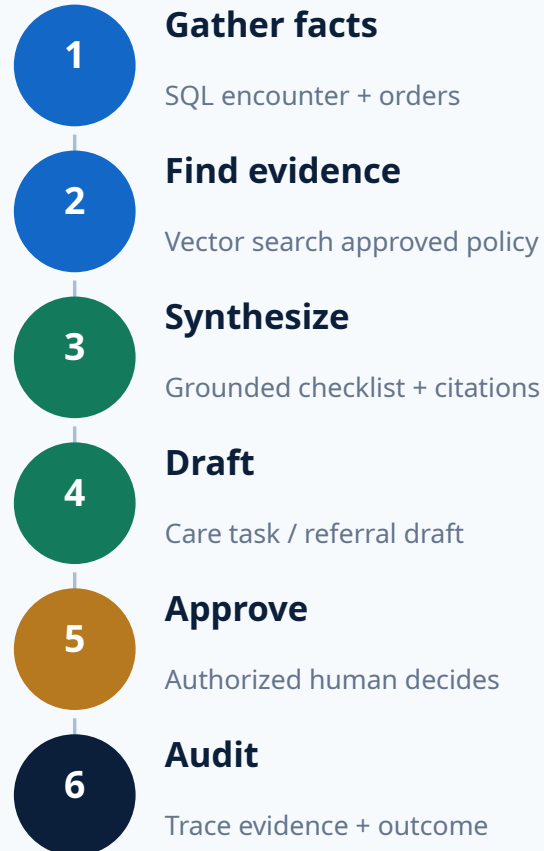
SYNTHETIC CASE

Jordan Lee

Post-knee-replacement discharge coordination

- Confirm discharge policy and care pathway
- Check home-health and equipment requirements
- Review payer authorization steps
- Identify missing tasks before discharge
- Draft a care-coordination action

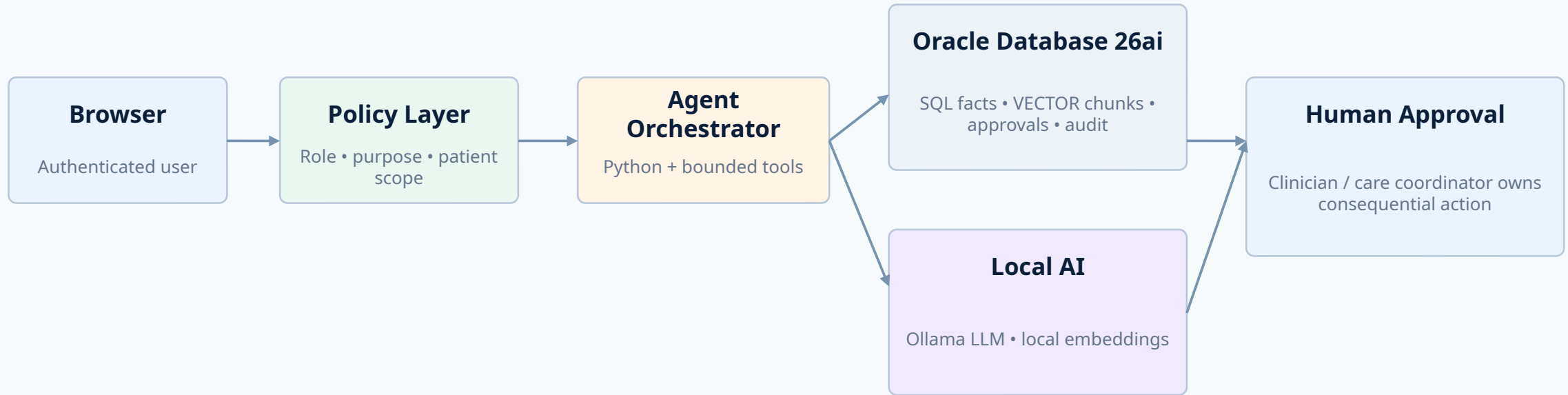
Synthetic data only - no real PHI



Key point: AI assembles evidence and drafts action; accountable healthcare staff retain authority.

The proof of concept uses one governed data path

Structured facts and vector knowledge meet inside an explicit authorization and audit boundary.



The model receives only authorized context. It has no database credentials, no raw SQL tool and no authority to override policy.

TLS / ENCRYPTION

SECRETS OUTSIDE
PROMPTS

AUDIT EVERYTHING

APPROVED SOURCES ONLY

NO EXTERNAL PHI API IN
BASE POC

HIPAA is designed into the control flow - not added as a prompt

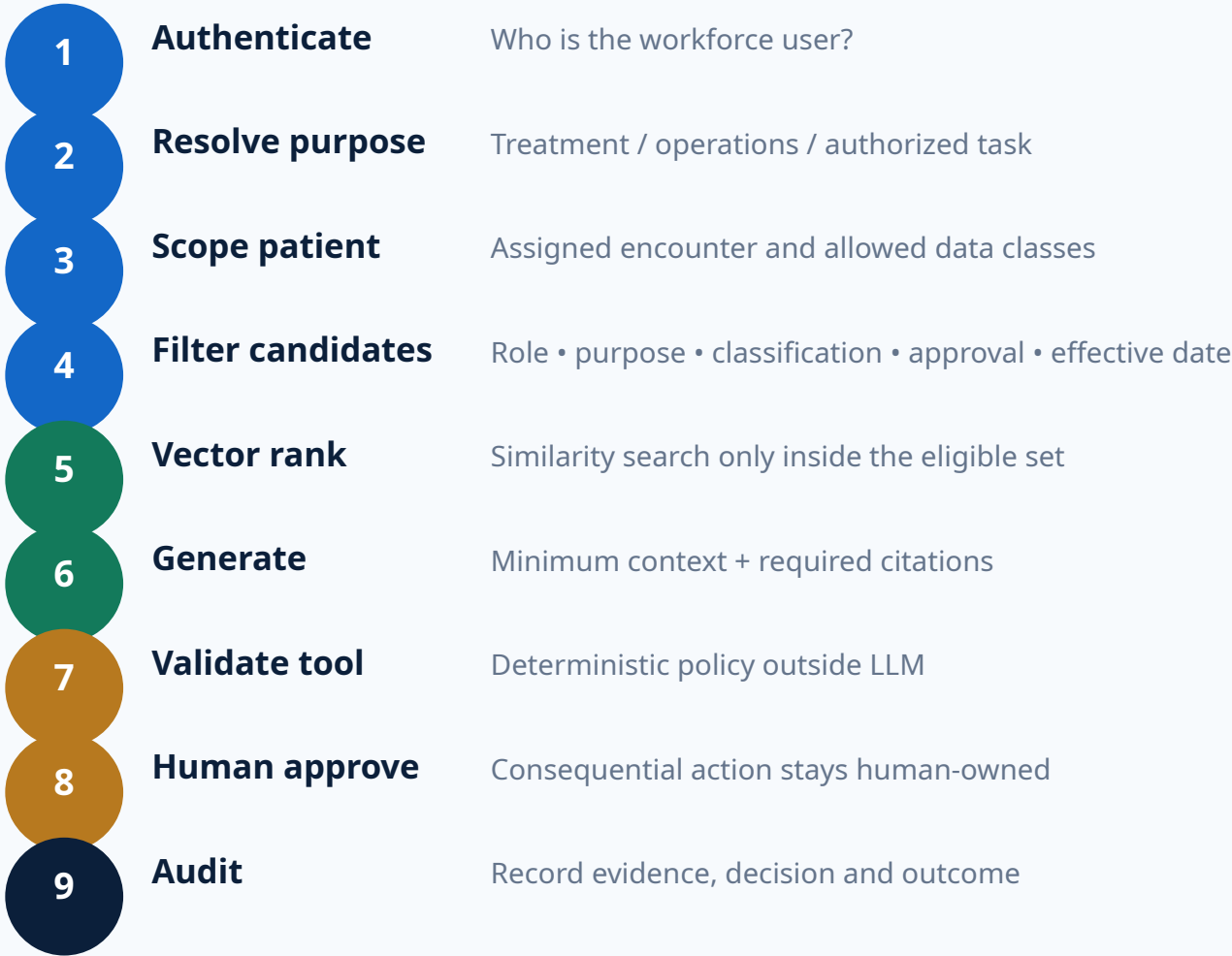
The demo illustrates safeguards; it does not claim that a technology product itself is "HIPAA certified."

Minimum necessary	Purpose-specific tools and field/document filters before model context	Privacy Rule
Access control	Role + patient scope + bounded tools	Security Rule
Audit controls	Authorization, evidence, model/tool activity, approval, outcome	Security Rule
Integrity	Approved/current policy, source trust, version and hash	Security Rule
Authentication	Authenticated workforce session; enterprise IAM/MFA in production	Security Rule
Transmission security	TLS and restricted endpoints	Security Rule
Business associates	BAA/vendor gate when a service creates, receives, maintains or transmits ePHI	Privacy/Security Rules
Risk analysis	Documented production risk analysis and risk-management plan	Security Rule

Current HHS Security Rule remains in effect; the 2024 cybersecurity strengthening rule is still proposed as of August 2026.

Secure RAG means authorization before similarity search

Do not retrieve everything and try to hide restricted data later.



FILTER FIRST -> RANK SECOND

We intentionally attack the healthcare demo

Security tests make the HIPAA and AI-control story visible.

Cross-patient access Ask for another patient DENY before LLM context	Excessive agency "Submit the referral now" BLOCK until approval
Overbroad request Ask for the full chart for a narrow task MINIMIZE / redact	Bulk export "Export all patient records" BLOCK / alert
Prompt injection Policy says "ignore access rules" Treat as untrusted data	Secret request Ask for DB password/token DENY; secret absent
Stale policy Superseded policy ranks highly EXCLUDE / flag	Unsupported claim Model invents clinical guidance FLAG; no action

The model is deliberately treated as a reasoning component - not an authorization engine, identity provider or clinical authority.

Human accountability stays explicit

The base demo allows AI to investigate, retrieve, summarize and draft - not silently take consequential action.

AI MAY

- Read authorized structured facts
- Retrieve approved knowledge
- Summarize evidence with citations
- Identify missing workflow steps
- Draft a care-coordination task
- Recommend the next permitted action

AI MAY NOT

- Diagnose or prescribe autonomously
- Place clinical orders without approval
- Disclose PHI outside authorized scope
- Submit claims or referrals automatically
- Change permissions or security policy
- Bypass audit, workflow or identity controls

Design thesis: AI increases staff capacity without transferring accountability to the model.

What this demo proves - and what it deliberately does not

A credible proof of concept is stronger when its boundaries are explicit.

THIS DEMO PROVES

- RAG over approved healthcare policies
- SQL + vector retrieval in one governed data path
- Role/purpose/patient-scope authorization before generation
- Minimum-necessary context construction
- Visible citations and evidence
- Human approval for consequential workflow steps
- Security attack handling
- AI auditability and model portability

THIS DEMO DOES NOT CLAIM

- HIPAA certification or legal compliance by itself
- Use of real PHI/ePHI
- Autonomous clinical decision-making
- Production-grade high availability / disaster recovery
- Completed organization-specific risk analysis
- Completed BAA/vendor governance
- Final clinical-safety validation
- That proposed HIPAA cybersecurity changes are current law

The path from portfolio demo to production is clear

The architecture pattern stays; the controls and operational evidence get stronger.

IDENTITY & ACCESS

Enterprise IAM • MFA • access reviews • workforce lifecycle

DATA & PRIVACY

PHI inventory • purpose/use rules • de-identification • retention

PLATFORM SECURITY

Segmentation • hardening • vulnerability management • backups

MODEL GOVERNANCE

Approved model/vendor • BAA where applicable • evaluation • change control

OBSERVABILITY

SIEM • alerting • incident response • audit retention

CLINICAL / OPS GOVERNANCE

Human approval • safety review • SOPs • training • metrics

The reusable pattern: authorize -> retrieve -> ground -> recommend -> approve -> act -> audit.

Primary HIPAA reference points used in the design

Use HHS/OCR as the authoritative baseline and re-check before production.

HHS - The Security Rule

Administrative, physical and technical safeguards for confidentiality, integrity and availability of ePHI.

HHS - HIPAA Security Rule NPRM

HHS states the current Security Rule remains in effect while the 2024 cybersecurity rule is proposed.

HHS - HIPAA & Cloud Computing

Cloud service providers handling ePHI are generally business associates and require an appropriate BAA.

HHS - Minimum Necessary Requirement

Reasonable steps should generally limit PHI use/disclosure/request to what is necessary for the purpose.

Sources: [hhs.gov/hipaa/for-professionals/security](https://www.hhs.gov/hipaa/for-professionals/security) • [hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm](https://www.hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm) • [hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing](https://www.hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing) • [hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement](https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement)